SYSTEM CLASSIFICATION QUESTIONNAIRE

WI-005 | Work Instruction | Issued under SOP-005 / POL-005

Document ID: WI-005
Version: 1.0 — DRAFT
Parent SOP: SOP-005 — System Classification Process
Parent Policy: POL-005 — System Classification Policy
Classification: Internal Use
Owner: Information Security
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	System Classification Questionnaire
Document ID	WI-005
Version	1.0 — DRAFT
Document Type	Work Instruction — operational tool for use during system classification
Parent SOP	SOP-005 — System Classification Process (Step 3: Classification Assessment)
Parent Policy	POL-005 — System Classification Policy
Owner	Information Security
How to Use	Complete one questionnaire per system. Work through Parts A –E in order. Part D produces the Criticality Tier (Tier 1–4). Part E produces the Regulatory Flags. Part F records the final output. The System Classification Output in Part F is transferred to the System Register per SOP-005 Step 6.

NOTE: System classification is a two-axis output: (1) Criticality Tier (Tier 1–4) and (2) Regulatory Flags (GxP, SOX, GDPR/HIPAA, 21 CFR Part 11). The criticality tier is the higher of: (a) the data-derived tier from Part C, and (b) the functionally-derived tier from Part D. Both axes must be determined — a system cannot be classified with only one axis.

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for use

PART A — System Identification

Field	Response
System Name	
System Description (brief — what does it do?)	
System Type	☐ SaaS ☐ PaaS / IaaS ☐ On-premises application ☐ Database ☐ Infrastructure component ☐ Integration / middleware ☐ Development / test environment
Hosting Model	☐ On-premises ☐ Private cloud ☐ Public cloud (provider: _____) ☐ Vendor-hosted SaaS ☐ Hybrid
System Owner (Business)	
Data Custodian (IT)	
Date of Classification	
Previous Tier (if reclassification)	
Trigger for this Classification (per SOP-005 §3.1)	☐ New system ☐ Annual review ☐ Material change in function / data ☐ Regulatory change ☐ Post-incident review ☐ BIA output ☐ Merger / acquisition
Vendor / Supplier (if applicable)	
List of integrated systems (systems this system sends/receives data to/from)	

PART B — Data Content Assessment

Identify the highest-sensitivity data held or processed by this system. Use WI-001 (Data Classification Questionnaire) to classify individual data assets if not already classified. The system's data-sensitivity level is the highest sensitivity tier of any data asset the system holds, processes, or transmits.

Data Asset / Type	Classified Sensitivity Tier (from WI-001 or Asset Register)	Volume / Scope	GxP?	Personal Data?	PHI?	Financial / SOX?
	☐ PUBLIC ☐ INTERNAL ☐		☐	☐	☐	☐

Data Asset / Type	Classified Sensitivity Tier (from WI-001 or Asset Register)	Volume / Scope	GxP?	Personal Data?	PHI?	Financial / SOX?
	CONFIDENTIAL ☐ SENSITIVE					
	☐ PUBLIC ☐ INTERNAL ☐ CONFIDENTIAL ☐ SENSITIVE		☐	☐	☐	☐
	☐ PUBLIC ☐ INTERNAL ☐ CONFIDENTIAL ☐ SENSITIVE		☐	☐	☐	☐
	☐ PUBLIC ☐ INTERNAL ☐ CONFIDENTIAL ☐ SENSITIVE		☐	☐	☐	☐
(add rows as needed)						

	Data-Derived Tier
Highest data sensitivity tier in this system:	☐ PUBLIC ☐ INTERNAL USE ☐ CONFIDENTIAL ☐ SENSITIVE
Data-derived criticality tier (map: PUBLIC→Tier 4; INTERNAL→Tier 3; CONFIDENTIAL→Tier 2; SENSITIVE→Tier 1):	☐ Tier 1 ☐ Tier 2 ☐ Tier 3 ☐ Tier 4

NOTE: Data-derived tier mapping per POL-005: a system holding SENSITIVE data is data-derived Tier 1 (Extremely Critical). A system holding CONFIDENTIAL data is data-derived Tier 2 (Business Critical). INTERNAL USE → Tier 3. PUBLIC → Tier 4. This is the floor — functional criticality (Part D) may raise it further but can never lower it below the data-derived tier.

PART C — System Dependency Assessment

A system that is a critical dependency of a higher-tier system inherits that system's tier for recovery priority purposes, even if its standalone classification would be lower. Complete this section to identify dependency-driven tier elevation.

Question	☐ YES	☐ NO	If YES — action
Is this system a direct dependency of a system already classified as Tier 1 (Extremely Critical)? (i.e., Tier 1 system cannot function or meet its RTO/RPO without this system)			→ This system inherits Tier 1 classification for recovery priority. Record Tier 1 dependency elevation below.
Is this system a direct dependency of a system already classified as Tier 2 (Business Critical) and not already classified Tier 1?			→ This system inherits Tier 2 classification for recovery priority. Record Tier 2 dependency elevation below.
Does a Tier 1 or Tier 2 system send or receive data to/from this system in a way that would compromise the higher-tier system's data integrity if this system were unavailable or corrupted?			→ Assess whether data integrity dependency raises this system's tier. Consult Information Security.

	Dependency Result
Dependency-driven tier elevation (if any):	☐ No elevation ☐ Elevated to Tier 1 ☐ Elevated to Tier 2 (reason: _____)

PART D — Functional Criticality Scoring

Score each dimension independently. The functional criticality tier is determined by the highest single score across all five dimensions — not the average. A single dimension scoring 4 or 5 is sufficient for Tier 1 or Tier 2 classification, regardless of other dimension scores.

D1 — Business Process Impact

What is the impact if this system is unavailable for 4 hours during business hours?

Score	Description	☐ Select
5 — Critical	Complete cessation of a core regulated or revenue-generating process. Direct patient safety risk, inability to release product, or	

Score	Description	☐ Select
	inability to process financial transactions.	
4 — Major	Significant disruption to a primary business process. Multiple departments affected. Manual workarounds not viable beyond 4 hours.	
3 — Moderate	Disruption to an important but non-core process. Manual workaround available but resource-intensive.	
2 — Minor	Limited disruption. Workaround available. Single team or small group affected.	
1 — Negligible	Minimal or no impact. System is supporting or reference only. Downtime does not affect business outcomes.	

D1 Score: _____

D2 — User Population and Reach

Score	Description	☐ Select
5 — Critical	Used by > 500 users organisation-wide, or by all users of a critical function, or used in external-facing regulated activities (e.g., clinical trial data entry, product release authorisation).	
4 — Major	Used by 100–500 users or by the entirety of one or more critical departments (R&D, Manufacturing, Finance, QA).	
3 — Moderate	Used by 25–99 users across multiple departments.	
2 — Minor	Used by fewer than 25 users or a single department.	
1 — Negligible	Used by fewer than 5 users. Individual or small team tool.	

D2 Score: _____

D3 — Recovery Time Requirement

How quickly must this system be restored to meet business requirements? (This is the business requirement — not the current DR capability.)

Score	Business RTO Requirement	☐ Select
5 — Critical	System must be available within 2 hours of disruption. No tolerable downtime beyond 2 hours.	
4 — Major	System must be available within 8 hours. Tolerable downtime: up to 8 hours.	

Score	Business RTO Requirement	☐ Select
3 — Moderate	System must be available within 24 hours.	
2 — Minor	System must be available within 72 hours.	
1 — Negligible	System recovery within 1 week is acceptable. No time-critical dependency.	

D3 Score: _____

D4 — Regulatory Process Involvement

Is this system directly involved in activities governed by GxP, SOX, GDPR, or HIPAA regulations?

Score	Description	☐ Select
5 — Critical	System is directly used in a GxP-regulated activity (batch record creation, product release, clinical data capture, laboratory data processing) or is a SOX-scoped system used in financial close processing.	
4 — Major	System supports (but does not directly execute) a GxP or SOX process, or is used to process a large volume of personal data under GDPR/HIPAA (> 10,000 data subjects or containing Special Category / PHI data).	
3 — Moderate	System processes personal data under GDPR/HIPAA but below the Tier 4 threshold, or supports a compliance reporting process without being directly in the regulated workflow.	
2 — Minor	System is subject to general GDPR requirements (processes employee or contact personal data) but not in a regulated workflow.	
1 — Negligible	No regulatory involvement. System processes only Public or Internal Use data with no regulatory flag.	

D4 Score: _____

D5 — Financial Reporting and Revenue Impact

What is the financial impact of this system's unavailability or data corruption?

Score	Description	☐ Select
5 — Critical	System unavailability or data corruption would: prevent financial close, trigger a material restatement, halt product shipment, or cause revenue loss > £500k per day of downtime.	
4 — Major	System is directly involved in order-to-cash, procure-to-pay, or a revenue-generating process. Revenue impact: £100k–£500k per day.	
3 — Moderate	System supports financial processes but is not in the critical path. Revenue impact: £10k–£100k per day.	
2 — Minor	Indirect financial impact only. Revenue impact < £10k per day.	
1 — Negligible	No direct or material financial impact.	

D5 Score: _____

D6 — Functional Criticality Score Summary

	Score
D1 — Business Process Impact	
D2 — User Population and Reach	
D3 — Recovery Time Requirement	
D4 — Regulatory Process Involvement	
D5 — Financial Reporting and Revenue Impact	
HIGHEST single dimension score (this is the functional criticality score):	

	Functional Tier
Functional Criticality Tier (map: score 5→Tier 1; score 4→Tier 1; score 3→Tier 2; score 2→Tier 3; score 1→Tier 4):	☐ Tier 1 ☐ Tier 2 ☐ Tier 3 ☐ Tier 4

NOTE: Score 5 or 4 on any single dimension → Tier 1 (Extremely Critical). Score 3 on any single dimension → Tier 2 (Business Critical). Score 2 → Tier 3 (Important). Score 1 → Tier 4 (Low Criticality). Tier is determined by the highest single dimension score — not the average across dimensions.

PART E — Composite Criticality Tier

Per POL-005, the system's criticality tier is the higher of: (a) the data-derived tier from Part B, and (b) the functional criticality tier from Part D. Dependency elevation from Part C is applied on top of this composite — it can only raise, never lower, the tier.

	Result
Data-derived tier (from Part B)	☐ Tier 1 ☐ Tier 2 ☐ Tier 3 ☐ Tier 4
Functional criticality tier (from Part D)	☐ Tier 1 ☐ Tier 2 ☐ Tier 3 ☐ Tier 4
Dependency elevation (from Part C)	☐ No elevation ☐ Tier 1 ☐ Tier 2
COMPOSITE CRITICALITY TIER (highest of the above three)	☐ Tier 1 — EXTREMELY CRITICAL ☐ Tier 2 — BUSINESS CRITICAL ☐ Tier 3 — IMPORTANT ☐ Tier 4 — LOW CRITICALITY

Tier Description Reference

Tier	Label	Characteristics	RTO / RPO	DR Testing
Tier 1	Extremely Critical	Core regulated or revenue-generating processes. Unavailability within hours causes regulatory non-compliance, patient safety risk, or major financial impact. Includes GxP systems directly in the regulated workflow and SOX systems in financial close.	RTO: 2hr / RPO: 1hr	Annual full failover test. Compliance / QA involved for GxP systems.
Tier 2	Business Critical	Important business processes. Unavailability within hours–days causes significant disruption but manual workarounds are available. Includes HR, QMS, non-GxP laboratory systems.	RTO: 8hr / RPO: 4hr	Annual tabletop exercise. Semi-annual for Tier 1 support systems.
Tier 3	Important	Departmental systems. Unavailability causes operational inconvenience but no material business impact within 24 hours.	RTO: 24hr / RPO: 24hr	Biennial plan review.
Tier 4	Low Criticality	Archival, development, or low-traffic internal tools. Extended unavailability has minimal business impact.	RTO: 72hr / RPO: 72hr	Triennial plan review.

PART F — Regulatory Flag Determination

Regulatory flags are determined independently of the criticality tier. A flag adds specific compliance requirements (validation, access controls, audit trail standards, retention periods) on top of the tier-based controls. Flags are cumulative — a system may carry multiple flags simultaneously.

Flag	Determining Questions	□ Yes / □ No	Consequence if Flagged
GxP (Good Practice — manufacturing, laboratory, clinical)	Is this system directly used to create, process, modify, maintain, archive, retrieve, or transmit GxP records (batch records, laboratory data, clinical trial data, QC data, stability data)? OR: Is this system used to control, monitor, or record GxP-regulated equipment or processes?		Track A validation (POL-006) mandatory. Computer System Validation Plan, IQ/OQ/PQ, VMF required. ALCOA+ data integrity controls (POL-003/SOP-003). Audit trail immutability per POL-014 §5.1. Manual backup procedure required (POL-011). GxP exception handling (EXC-001).
21 CFR Part 11 (FDA electronic records and signatures)	Is this system used to create or manage electronic records that are required by FDA regulations, or used as a substitute for paper records in FDA-regulated activities? OR: Does this system use electronic signatures that are legally binding in an FDA-regulated context?		Part 11 compliant audit trail (before/after values, immutability, no disable capability). Validated system controls. Electronic signature controls per §11.50 and §11.70. Audit trail validated in OQ (POL-006/POL-014).
EU Annex 11 (EMA computerised systems)	Is this system used in EU-regulated GMP/GCP/GDP activities and subject to EMA Annex 11 requirements?		Annex 11 §4 supplier assessment. §9 audit trail. §12 incident management. §13 disaster recovery validated. §17 archiving. Compliance assessed by Compliance / QA against Annex 11 checklist.
SOX (Sarbanes-Oxley ITGC)	Is this system used to process, record, or report financial transactions that feed into [Company Name]'s financial statements? OR: Is this system an ITGC-relevant control (access management, change management) for a financial reporting system?		ITGC audit trail (7-year retention — POL-002). Quarterly access review (POL-008). Change management evidence (POL-007). Financial close change freeze. SOX ITGC testing by Internal Audit. External auditor access to audit trail.
GDPR (EU/UK General Data Protection Regulation)	Does this system process personal data of EU or UK data subjects (including employees, customers, clinical trial participants, or contacts)?		ROPA entry required (SOP-004). DPIA if high-risk processing (SOP-004). DPA for any third-party processor (POL-013). Data subject rights capability required. Breach notification capability

Flag	Determining Questions	☐ Yes / ☐ No	Consequence if Flagged
			(POL-012/SOP-004). GDPR retention periods apply (POL-002).
HIPAA (US Health Insurance Portability and Accountability Act)	Does this system create, receive, maintain, or transmit Protected Health Information (PHI) as defined under HIPAA?		BAA with any processor required (POL-013). Minimum Necessary rule. HIPAA-compliant audit controls. Breach notification obligations (POL-012/SOP-004). HIPAA 6-year audit log retention (POL-002/POL-014).
CCPA (California Consumer Privacy Act)	Does this system process personal information of California residents in a commercial context, and does [Company Name] meet CCPA applicability thresholds?		Privacy notice requirements. Consumer rights capability (opt-out, deletion, access). DPO assessment recommended. Note: CCPA/CPRA obligations may be covered by GDPR compliance programme — DPO to confirm.

F2 — Regulatory Flag Summary

	Flag Summary
Flags assigned to this system:	☐ GxP ☐ 21 CFR Part 11 ☐ EU Annex 11 ☐ SOX ☐ GDPR ☐ HIPAA ☐ CCPA ☐ None
Does this system carry GxP flag?	☐ YES — validation programme must be initiated per POL-006 before system is used in regulated activities ☐ NO
Does this system carry SOX flag?	☐ YES — Internal Audit and CFO notified; ITGC controls programme initiated ☐ NO
Does this system carry GDPR/HIPAA flag?	☐ YES — DPO notified; ROPA entry and DPIA assessment initiated per SOP-004 ☐ NO

PART G — Classification Output and System Register Entry

Record the final classification result. This is the definitive output of this questionnaire. Transfer all fields to the System Register per SOP-005 Step 6.

G1 — Classification Summary

	Result
System Name	
Criticality Tier	☐ Tier 1 — Extremely Critical ☐ Tier 2 — Business Critical ☐ Tier 3 — Important ☐ Tier 4 — Low Criticality
Tier basis	☐ Data-derived ☐ Functional ☐ Dependency elevation ☐ Combined (data + functional)
Tier-determining factor(s)	(e.g., "D4 score 5 — system directly processes GxP batch records"): _____
Regulatory Flags	☐ GxP ☐ 21 CFR Part 11 ☐ EU Annex 11 ☐ SOX ☐ GDPR ☐ HIPAA ☐ CCPA ☐ None
Data Sensitivity (from Part B)	☐ PUBLIC ☐ INTERNAL USE ☐ CONFIDENTIAL ☐ SENSITIVE
Hosting Model	☐ On-premises ☐ Cloud ☐ SaaS ☐ Hybrid
Recovery Targets	RTO: _____ RPO: _____ (per tier from Part E or system-specific BIA if more aggressive)

G2 — Controls Initiation Checklist

Confirm the following actions are initiated or confirmed as complete based on the classification output above.

Control / Action	Applies?	Status	Owner	Target Date
System Register entry created / updated (SOP-005 Step 6)	All tiers	☐ Complete		
BIA conducted and RTO/RPO confirmed (POL-011)	Tier 1 and Tier 2	☐ Complete ☐ Initiated ☐ N/A		
DR architecture designed and documented (POL-011)	Tier 1 and Tier 2	☐ Complete ☐ Initiated ☐		

Control / Action	Applies?	Status	Owner	Target Date
		N/A		
Validation programme initiated (POL-006)	GxP flag only	☐ Complete ☐ Initiated ☐ N/A		
Vendor qualification initiated (POL-013)	GxP flag — vendor-hosted systems	☐ Complete ☐ Initiated ☐ N/A		
Audit trail compliance confirmed (POL-014)	GxP, Tier 1, SOX	☐ Complete ☐ Initiated ☐ N/A		
SIEM log forwarding configured (POL-014)	Tier 1 and Tier 2	☐ Complete ☐ Initiated ☐ N/A		
Access control review completed (POL-008)	Tier 1 and Tier 2, GxP, SOX	☐ Complete ☐ Initiated ☐ N/A		
PAM controls applied (POL-009)	Tier 1, GxP, SOX — privileged access only	☐ Complete ☐ Initiated ☐ N/A		
ROPA entry created / DPIA initiated (SOP-004)	GDPR or HIPAA flag	☐ Complete ☐ Initiated ☐ N/A		
DPA / BAA executed with any processors (POL-013)	GDPR / HIPAA flag with third-party processing	☐ Complete ☐ Initiated ☐ N/A		
ITGC controls programme notified to Internal Audit	SOX flag	☐ Complete ☐ Initiated ☐ N/A		
Change management controls verified (POL-007)	Tier 1, Tier 2, GxP, SOX	☐ Complete ☐ Initiated ☐ N/A		

G3 — Approvals

	Detail
Classification completed by	_____ (Name / Role)
Date	_____
System Owner confirmation	☐ System Owner has reviewed and confirmed this classification
System Owner signature / approval reference	_____

	Detail
Information Security review	☐ Information Security has reviewed and confirmed this classification Reviewed by: _____ Date: _____
Compliance / QA sign-off (GxP systems only)	☐ Compliance / QA has confirmed GxP flag and initiated validation programme requirements Name: _____ Date: _____ ☐ N/A — no GxP flag
DPO notification (GDPR/HIPAA systems only)	☐ DPO notified and ROPA/DPIA process initiated ☐ N/A — no GDPR/HIPAA flag
System Register entry confirmed	☐ Entry created / updated in System Register per SOP-005 Step 6 Register reference: _____
Next scheduled review date	_____ (12 months from classification date, or earlier if trigger event per SOP-005)
Notes / exceptions	

G4 — Worked Example: Composite Tier Determination

GxP: Example: A QMS (Quality Management System) that stores GxP deviation records and CAPA documentation. • Data content: GxP records (SENSITIVE) → Data-derived tier: Tier 1 • D1 — Business process impact: score 4 (significant disruption to QA process — GxP release activities affected if unavailable > 4 hours) → Tier 1 • D2 — User population: score 3 (QA department, ~40 users) → Tier 2 • D3 — Recovery time requirement: score 4 (must be available within 8 hours to avoid regulatory breach of batch release timelines) → Tier 1 • D4 — Regulatory involvement: score 5 (directly used in GxP CAPA process which is a regulatory requirement) → Tier 1 • D5 — Financial impact: score 3 (batch delays have indirect revenue impact) → Tier 2 Highest functional dimension score: 5 → Functional tier: Tier 1 Data-derived tier: Tier 1 Dependency elevation: None COMPOSITE TIER: Tier 1 — Extremely Critical REGULATORY FLAGS: GxP, EU Annex 11, 21 CFR Part 11 (if US operations), GDPR (if employee personal data in CAPA records)

— End of Questionnaire —

WI-005 v1.0 DRAFT | [Company Name] | INTERNAL USE